

Aetheris Therapeutics S.p.A. — Audit Clausole Obbligatorie (4 - 10)

Rappresentazione formale della valutazione d'audit sui 30 Requisiti del SGSI con esito ispettivo e Rilievi di Audit sulle evidenze emerse dal campo.

Clausola 4: Contesto dell'Organizzazione (Context of the Organisation)

Requisito 4.1 Comprendere l'organizzazione e il suo contesto

NON CONFORME (FAIL)

 **Rilievo ed Evidenze d'Audit:** L'analisi dei fattori interni ed esterni non è formalizzata in un documento di contesto. Nonostante l'azienda gestisca IP critica e brevetti, manca un riesame periodico strutturato dei rischi di contesto.

Requisito 4.2 Comprendere le esigenze e le aspettative delle parti interessate

NON CONFORME (FAIL)

 **Rilievo ed Evidenze d'Audit:** I requisiti di parti interessate (Garante Privacy, EMA, clienti clinici) non sono mappati in un registro formale. Manca il tracciamento dei vincoli normativi legati alla sicurezza.

Requisito 4.3 Determinare il campo di applicazione (Scope) del SGSI

CONFORME (PASS)

 **Rilievo ed Evidenze d'Audit:** Il perimetro aziendale è chiaramente identificato nell'infrastruttura ibrida (On-Premise + Azure Cloud) a supporto dei laboratori di R&D e della sede centrale.

Requisito 4.4 Sistema di gestione della sicurezza delle informazioni

NON CONFORME (FAIL)

 **Rilievo ed Evidenze d'Audit:** Il SGSI non è ancora formalmente istituito o documentato in modo integrato. L'operatività di sicurezza è gestita in modo frammentato dall'IT.

Clausola 5: Leadership

Requisito 5.1 Leadership e impegno

NON CONFORME (FAIL)

 **Rilievo ed Evidenze d'Audit:** La direzione è focalizzata sui rischi finanziari e di ricerca clinica, ma non partecipa a comitati di sicurezza né stanZIA un budget dedicato alla cybersecurity.

Requisito 5.2 Politica per la sicurezza delle informazioni

NON CONFORME (FAIL)

 **Rilievo ed Evidenze d'Audit:** Manca una Information Security Policy (ISP) di alto livello firmata dal C-Level. È presente solo una linea guida IT operativa di base.

Requisito 5.3 Ruoli, responsabilità e autorità organizzative

NON CONFORME (FAIL)

 **Rilievo ed Evidenze d'Audit:** I ruoli di sicurezza non sono formalmente assegnati (manca la figura del CISO/ISMS Owner). Le attività sono delegate in blocco all'IT Manager.

Clausola 6: Pianificazione (Planning)

Requisito 6.1.1 Azioni generali per affrontare rischi e opportunità

NON CONFORME (FAIL)

 **Rilievo ed Evidenze d'Audit:** Non esiste una procedura aziendale strutturata per la gestione continuativa dei rischi tecnologici e delle opportunità di miglioramento del SGSI.

Requisito 6.1.2 Valutazione dei rischi (Risk Assessment)

NON CONFORME (FAIL)

 **Rilievo ed Evidenze d'Audit:** Manca una metodologia formale di Risk Assessment (es. ISO 27005/31000). Non vengono attribuiti i Risk Owner né valutati i criteri C-I-A sugli asset.

Requisito 6.1.3 Trattamento dei rischi (Risk Treatment)

NON CONFORME (FAIL)

 **Rilievo ed Evidenze d'Audit:** Non esiste un Risk Treatment Plan (RTP) approvato dai Risk Owner. La Statement of Applicability (SoA) non era precedentemente definita.

Requisito 6.2 Obiettivi di sicurezza e pianificazione

NON CONFORME (FAIL)

 **Rilievo ed Evidenze d'Audit:** Non sono definiti KPI o KRI di sicurezza delle informazioni da monitorare e rendicontare alla direzione a cadenza periodica.

Requisito 6.3 Pianificazione delle modifiche

NON CONFORME (FAIL)

 **Rilievo ed Evidenze d'Audit:** Manca un comitato o processo formale di Change Management per valutare l'impatto di sicurezza prima dell'introduzione di modifiche infrastrutturali.

Clausola 7: Supporto (Support)

Requisito 7.1 Risorse

CONFORME (PASS)

 **Rilievo ed Evidenze d'Audit:** L'azienda fornisce adeguate risorse economico-tecnologiche per l'infrastruttura di base (firewall Palo Alto, ambienti Azure, storage).

Requisito 7.2 Competenza

NON CONFORME (FAIL)

 **Rilievo ed Evidenze d'Audit:** Non vengono definiti i requisiti di competenza cibernetica per il personale IT/Security, né sono conservati registri di formazione specialistica.

Requisito 7.3 Consapevolezza (Awareness)

NON CONFORME (FAIL)

 **Rilievo ed Evidenze d'Audit:** La formazione si limita a un modulo d'ingresso per i neoassunti. Mancano corsi di aggiornamento periodici e campagne di simulazione phishing.

Requisito 7.4 Comunicazione**NON CONFORME (FAIL)**

 **Rilievo ed Evidenze d'Audit:** Non esistono canali di comunicazione stabiliti per la notifica formale di incidenti a stakeholder interni, organi regolatori (GDPR) o terze parti.

Requisito 7.5.1 Informazioni documentate - Generalità**NON CONFORME (FAIL)**

 **Rilievo ed Evidenze d'Audit:** La documentazione minima prescritta dalla ISO 27001 (policy, registri, procedure) è quasi del tutto assente o frammentata.

Requisito 7.5.2 Creazione e aggiornamento dei documenti**NON CONFORME (FAIL)**

 **Rilievo ed Evidenze d'Audit:** Non è applicato uno standard formale di versioning, riesame e approvazione dei documenti tecnici e procedurali.

Requisito 7.5.3 Controllo delle informazioni documentate**NON CONFORME (FAIL)**

 **Rilievo ed Evidenze d'Audit:** La documentazione tecnica è conservata in share di rete senza cifratura o controlli d'accesso granulari basati sui ruoli.

Clausola 8: Attività Operative (Operation)**Requisito 8.1 Pianificazione e controllo operativi****CONFORME PARZIALE (PASS)**

 **Rilievo ed Evidenze d'Audit:** Le operation IT ordinarie (gestione domini, manutenzione di rete) seguono prassi consolidated, ma mancano procedure operative formalizzate.

Requisito 8.2 Valutazione dei rischi operativi**NON CONFORME (FAIL)**

 **Rilievo ed Evidenze d'Audit:** Non vengono eseguiti Risk Assessment operativi prima dell'integrazione di nuove piattaforme SaaS o modifiche di rete.

Requisito 8.3 Trattamento dei rischi operativi**NON CONFORME (FAIL)**

 **Rilievo ed Evidenze d'Audit:** Mancando il Risk Treatment Plan, non vi sono evidenze dell'attuazione sistematica di azioni di mitigazione del rischio operante.

Clausola 9: Valutazione delle Prestazioni (Performance Evaluation)**Requisito 9.1 Monitoraggio, misurazione, analisi e valutazione****NON CONFORME (FAIL)**

 **Rilievo ed Evidenze d'Audit:** In assenza di un SIEM o di metriche centralizzate, l'efficacia dei controlli di sicurezza non viene analizzata o misurata numericamente.

Requisito 9.2.1 Audit interno - Generalità**NON CONFORME (FAIL)**

 **Rilievo ed Evidenze d'Audit:** L'organizzazione non ha mai condotto audit interni del SGSI per verificare la conformità ai requisiti della ISO 27001.

Requisito 9.2.2 Programma di audit interno**NON CONFORME (FAIL)**

 **Rilievo ed Evidenze d'Audit:** Non esiste un programma o calendario triennale/annuale di audit interni approvato dalla direzione.

Requisito 9.3.1 Riesame della direzione - Generalità**NON CONFORME (FAIL)**

 **Rilievo ed Evidenze d'Audit:** Il Management Review del SGSI non viene svolto, privando la direzione della supervisione strategica sulla sicurezza.

Requisito 9.3.2 Input del riesame della direzione**NON CONFORME (FAIL)**

 **Rilievo ed Evidenze d'Audit:** Non vengono formalizzati o raccolti i verbali e gli input prescritti (risultati audit, KPI, stato dei rischi, incidenti).

Requisito 9.3.3 Output del riesame della direzione**NON CONFORME (FAIL)**

 **Rilievo ed Evidenze d'Audit:** Mancando il riesame, non vi sono decisioni verbalizzate della direzione per l'allocazione di budget e risorse di remediation.

Clausola 10: Miglioramento (Improvement)**Requisito 10.1 Miglioramento continuo****NON CONFORME (FAIL)**

 **Rilievo ed Evidenze d'Audit:** Il miglioramento dell'infrastruttura avviene solo su spinta reattiva (emergenze), anziché tramite un ciclo PDCA strutturato.

Requisito 10.2 Non conformità ed azioni correttive**NON CONFORME (FAIL)**

 **Rilievo ed Evidenze d'Audit:** Non esiste un registro delle Non Conformità né viene svolta la Root Cause Analysis in seguito a guasti o incidenti di sicurezza.